Job 1 : Cadrage

Tableau « Valeur métier → Biens supports »

Valeur métier	Biens supports associés
Continuité du service de mobilité (vélos/trottinettes disponibles et utilisables)	Plateforme de supervision cloud, hébergeur cloud, API partenaires, boîtiers IoT, équipe DSI/exploitation
Sécurité physique des usagers (verrouillage/déverrouillage fiable, véhicules en bon état)	Boîtiers IoT embarqués, fournisseur des boîtiers, processus de mise à jour du firmware, plateforme de supervision
Intégrité de la facturation et du paiement	Application mobile (module de paiement), prestataire de paiement, API de paiement, base de données de facturation
Protection des données personnelles des usagers (identité, moyens de paiement, historique de trajets et de géolocalisation)	Bases de données utilisateurs, application mobile, hébergeur cloud, comptes d'administration
Confiance des collectivités (contrats de DSP)	Plateforme de supervision et reporting, indicateurs de service, équipe direction et relation clients, API partenaires
Image de marque et capacité de croissance (levée de fonds, nouvelles agglomérations)	Application mobile, communication et réseaux sociaux, ensemble des SI exposés au public

3 écarts de sécurité probables (guide d'hygiène ANSSI)

1. **Gestion des mises à jour et des correctifs, en particulier sur les boîtiers IoT.** L'incident du déverrouillage anormal d'une dizaine de véhicules suite à un défaut de mise à jour montre qu'il n'y a pas de processus maîtrisé : pas de test avant déploiement, pas de suivi du parc, pas de retour arrière prévu. Le guide d'hygiène demande de mettre à jour régulièrement les systèmes et de disposer d'un inventaire fiable.
2. **Authentification et gestion des comptes à privilèges.** MobiCité s'est développée très vite (+3 agglomérations en 18 mois) avec seulement 3 personnes dédiées à la sécurité. Il est donc probable que l'authentification multifacteur ne soit pas généralisée, que les droits administrateurs soient trop larges ou mal revus, et que les comptes des prestataires soient peu contrôlés. Le guide recommande de limiter les droits au strict nécessaire et de renforcer l'authentification.
3. **Journalisation et détection des événements de sécurité.** La tentative de fraude sur le paiement suggère une détection tardive ou partielle. Avec une plateforme cloud, une application et des API, il est probable qu'il n'y ait pas de centralisation des journaux ni d'alertes sur les comportements anormaux. Le guide préconise de journaliser les événements importants et de superviser les systèmes. Cet écart est aussi lié à l'ouverture envisagée des API, qui augmentera la surface d'attaque.

Job 2 : Événements redoutés et échelle de gravité

Échelle de gravité (4 niveaux)

Niveau	Libellé	Critères concrets
G1	Mineure	Gêne limitée : interruption < 2h sur une seule agglomération, impact financier < 10k €, aucun usager affecté physiquement, pas de données personnelles exposées.
G2	Significative	Interruption de 2h à 24h sur 1 à 2 agglomérations, perte de 10 à 100k €, plaintes d'usagers, couverture médiatique locale, sans blessé ni fuite de données avérée.
G3	Grave	Interruption > 24 h ou touchant plusieurs agglomérations, perte de 100k € à 1M €, fuite de données de milliers d'usagers (notification CNIL), pénalités contractuelles ou avertissement formel d'une collectivité, blessures légères possibles.
G4	Critique	Arrêt du service > 72h ou sur l'ensemble des agglomérations, perte > 1M €, atteinte physique grave d'usagers, fuite massive de données sensibles (paiement, géolocalisation), résiliation d'une DSP, non-renouvellement de l'assurance cyber ou levée de fonds compromise.

Tableau « Valeur métier → Événement redouté → Gravité → Justification »

Valeur métier	Événement redouté	Gravité	Justification
Continuité du service de mobilité	Indisponibilité prolongée de la plateforme de supervision et de l'application (ex. chiffrement du cloud par un ransomware)	**G4**	Les 6 agglomérations seraient paralysées plusieurs jours, avec des pertes de revenus et un risque de résiliation des DSP.
Sécurité physique des usagers	Prise de contrôle ou dysfonctionnement des boîtiers IoT provoquant un verrouillage ou un déverrouillage intempestif en circulation	**G4**	Un usager pourrait être gravement blessé, ce qui engage la responsabilité de MobiCité et peut entraîner le retrait des véhicules.
Intégrité de la facturation et du paiement	Fraude ou manipulation des paiements (débits frauduleux, facturations erronées en masse)	**G3**	Perte financière directe et perte de confiance des usagers, mais l'impact est limité dans le temps et corrigeable par remboursement.

Protection des données personnelles	Fuite ou vol des données utilisateurs (identité, historique de trajets et de géolocalisation)	**G3**	Des milliers d'usagers seraient concernés, avec une notification à la CNIL et un risque de sanction RGPD. Les données de géolocalisation sont sensibles.
Confiance des collectivités (DSP)	Manquement aux niveaux de service ou perte des données de reporting, entraînant pénalités ou non-renouvellement d'un contrat	**G3**	Les contrats de DSP sont le cœur du modèle économique, mais l'impact est généralement progressif (pénalités puis perte d'un contrat, plutôt que des six d'un coup).
Image de marque et croissance	Médiatisation d'un incident (véhicules déverrouillés, fuite) qui nuit à la réputation et à la levée de fonds	**G2**	L'impact est surtout indirect et dépend de la couverture médiatique. Il est plus faible que les événements techniques qui le provoquent.

Job 3 : Sources de risque et objectifs visés (SR/OV)

N°	Source de risque (SR)	Objectif visé (OV)	Justification
1	Cybercriminel organisé (groupe de rançongiciel)	Extorquer une rançon en chiffrant la plateforme cloud et en paralysant le service	MobiCité est une cible rentable : un service public paralysé met une forte pression pour payer, et la levée de fonds récente laisse supposer de la trésorerie.
2	Cybercriminel fraudeur	Détourner des paiements ou utiliser gratuitement le service via l'application et les API de paiement	La tentative de fraude récente montre que le module de paiement est déjà testé, et l'ouverture des API élargirait encore les possibilités.
3	Cybercriminel opportuniste (revendeur de données)	Voler et revendre les données personnelles des usagers (identité, moyens de paiement, trajets)	Une base de milliers d'usagers avec des données de géolocalisation a une valeur marchande sur les places de marché criminelles.
4	Hacktiviste	Nuire à l'image de MobiCité et des collectivités partenaires (défiguration, détournement de véhicules, publication de données)	La mobilité partagée dans l'espace public est visible et parfois contestée, et une action spectaculaire sur des véhicules a un fort impact médiatique.

5	Initié malveillant (salarié ou prestataire mécontent)	Saboter le service ou exfiltrer des données par vengeance ou pour revendre des accès	Avec une croissance rapide, des droits d'accès larges et peu contrôlés, ainsi que des prestataires nombreux, un initié peut agir avec peu d'obstacles.
6	Concurrent (autre opérateur de mobilité)	Voler des informations stratégiques (contrats, tarifs, données d'usage, algorithmes de supervision) pour gagner des appels d'offres	MobiCité gagne des DSP face à d'autres opérateurs, donc ses données commerciales et d'exploitation ont un intérêt concurrentiel.
7	État ou acteur étatique	Prépositionnement et espionnage sur une infrastructure de mobilité urbaine, ou perturbation ciblée en contexte de tension	Les opérateurs de services urbains peuvent être des cibles de renseignement, mais l'intérêt est moins direct pour une entreprise de cette taille.

Job 4 : Cartographie et priorisation des couples SR/OV

Grille de cotation

Note	Motivation	Ressources (moyens techniques, financiers, accès)	Activité connue dans le secteur
1	Faible : intérêt marginal pour MobiCité	Limitées : attaques peu sophistiquées	Rare ou non observée sur la mobilité, les services urbains ou le transport
2	Moyenne : intérêt réel mais non prioritaire	Modérées : outils existants et compétences solides	Observée occasionnellement dans le secteur
3	Forte : gain direct, rapide et important	Importantes : groupe structuré, moyens ou accès privilégié	Fréquente et documentée, y compris sur des cibles comparables

Règle de sélection : score de pertinence = Motivation + Ressources + Activité connue. Un couple est retenu s'il atteint **7/9 ou plus**.

Tableau de notation

N°	Couple SR/OV	Motivation	Ressources	Activité connue	Total	Décision
1	Cybercriminel (rançongiciel) → rançon par chiffrement de la plateforme	3	3	3	**9**	✅ Retenu

2	Cybercriminel fraudeur → détournement de paiements	3	2	3	**8**	✅ Retenu
3	Revendeur de données → vol et revente des données usagers	3	2	2	**7**	✅ Retenu
4	Hacktiviste → atteinte à l'image, détournement de véhicules	2	1	2	**5**	❌ Écarté
5	Initié malveillant → sabotage ou exfiltration	1	3	2	**6**	❌ Écarté
6	Concurrent → vol d'informations stratégiques	2	2	1	**5**	❌ Écarté
7	État → espionnage ou prépositionnement	1	3	1	**5**	❌ Écarté

Sélection finale et justification

- **Couple 1 (rançongiciel), 9/9.** C'est le plus pertinent : forte motivation financière, groupes très structurés et attaques très fréquentes sur des opérateurs de services. Il vise l'événement redouté le plus grave du Job 2 (indisponibilité prolongée, G4).
- **Couple 2 (fraude au paiement), 8/9.** La tentative de fraude récente prouve que MobiCité est déjà dans le viseur. Les moyens nécessaires sont accessibles et l'ouverture envisagée des API augmente l'exposition.
- **Couple 3 (revente de données), 7/9.** La valeur marchande des données (identité, paiement, géolocalisation) est élevée et ce type de vol est très courant. Il correspond à l'événement redouté « fuite de données » et à ses conséquences RGPD.

Couples écartés : ils ne sont pas jugés négligeables, mais moins prioritaires à ce stade. L'initié (6/9) reste à surveiller, car il a un accès légitime mais peu de motivation avérée. L'État et le concurrent ont une activité connue faible sur ce type de cible.

Job 5 : Scénarios stratégiques et chemins d'attaque

Scénario 1 : Rançongiciel via le fournisseur des boîtiers IoT

Couple SR/OV : cybercriminel (rançongiciel) → extorquer une rançon en paralysant la plateforme.
Partie prenante point d'entrée : le **fournisseur des boîtiers IoT**. Il dispose d'accès de maintenance et d'un canal de mise à jour vers la flotte et la plateforme, et l'incident récent de mise à jour montre que ce processus est mal maîtrisé.

Étape	Description
1	Le cybercriminel repère le fournisseur IoT comme maillon faible (petite structure, sécurité moindre) et compromet l'un de ses comptes (phishing, identifiants volés).

2	Il exploite les accès de maintenance ou le canal de mise à jour du fournisseur pour atteindre l'environnement de MobiCité.
3	Il prend pied sur la plateforme de supervision cloud et élargit ses droits (comptes administrateurs, accès à l'hébergeur).
4	Il se déplace dans l'infrastructure, localise les systèmes critiques et les sauvegardes, puis les neutralise.
5	Il déclenche le chiffrement de la plateforme et des données et peut perturber les boîtiers IoT en même temps.
6	Il laisse une demande de rançon et menace de publier des données si elle n'est pas payée.

Événements redoutés liés (Job 2) : indisponibilité prolongée de la plateforme (**G4**) et dysfonctionnement des boîtiers IoT (**G4**), avec en conséquence possible le manquement aux niveaux de service des collectivités (**G3**).

Scénario 2 : Fraude au paiement via les API et le prestataire de paiement

Couple SR/OV : cybercriminel fraudeur → détourner des paiements ou utiliser le service gratuitement.
Partie prenante point d'entrée : le **prestataire de paiement** et les **API partenaires**, c'est-à-dire l'interface entre l'application et le paiement, déjà visée par une tentative de fraude.

Étape	Description
1	Le fraudeur étudie l'application mobile et les API exposées pour repérer les points faibles (contrôles insuffisants, limites de requêtes absentes).
2	Il crée ou récupère de nombreux comptes usagers (identifiants volés, comptes fictifs) pour tester à grande échelle.
3	Il exploite une faille de logique ou d'authentification dans l'API de paiement ou son intégration avec le prestataire.
4	Il génère des transactions frauduleuses (cartes volées testées, paiements contournés, remboursements indus).
5	Il encaisse les gains ou utilise le service gratuitement, tant que la détection reste tardive.

Événements redoutés liés (Job 2) : fraude ou manipulation des paiements (**G3**) et, en cas de médiatisation, atteinte à l'image de marque (**G2**).

Scénario 3 : Vol de données via l'hébergeur cloud

Couple SR/OV : revendeur de données → voler et revendre les données personnelles des usagers.
Partie prenante point d'entrée : l'**hébergeur cloud.** Il concentre les bases de données, et une mauvaise configuration ou un compte d'administration compromis donnerait un accès direct.

Étape	Description
1	L'attaquant repère une exposition (stockage mal configuré, interface d'administration accessible) ou compromet un compte lié à l'hébergeur ou à un prestataire.
2	Il accède à l'environnement cloud de MobiCité avec des droits suffisants pour atteindre les bases utilisateurs.
3	Il localise les bases (identité, moyens de paiement, historique de trajets et de géolocalisation).
4	Il exfiltre les données lentement, pour passer inaperçu parmi le trafic normal.
5	Il revend ou publie les données sur des places de marché criminelles, avec un risque d'usage secondaire (phishing ciblé, usurpation).

Événements redoutés liés (Job 2) : fuite ou vol des données utilisateurs (**G3**), avec effet sur l'image de marque (**G2**) et la confiance des collectivités (**G3**).

Job 6 : Scénario opérationnel (chaîne d'attaque / kill chain)

Schéma de la chaîne d'attaque

① Reconnaissance → ② Intrusion initiale (chez le fournisseur IoT) → ③ Accès à MobiCité via le canal de maintenance → ④ Élévation de privilèges → ⑤ Propagation et neutralisation des sauvegardes → ⑥ Déploiement du rançongiciel → ⑦ Extorsion

Tableau « Étape → Vulnérabilité exploitée → Signal de détection possible »

Étape	Description	Vulnérabilité exploitée	Signal de détection possible
1. Reconnaissance	L'attaquant collecte des informations publiques : liste des prestataires de MobiCité, employés du fournisseur IoT sur les réseaux sociaux, services exposés sur Internet.	Informations publiques abondantes (communication sur la levée de fonds, partenaires visibles), absence de veille sur l'exposition externe.	Scans répétés sur les services exposés, tentatives de connexion inhabituelles sur les portails (visible si une supervision des accès externes existe).
2. Intrusion initiale	Un salarié du fournisseur IoT reçoit un phishing ciblé et saisit ses identifiants. L'attaquant obtient un compte de maintenance.	Authentification faible chez le fournisseur (pas de MFA), faible sensibilisation, aucune exigence de sécurité contractuelle envers le prestataire.	Alerte du fournisseur sur une connexion anormale (pays, horaire), pas visible côté MobiCité sans clause de notification.

3. Accès à MobiCité	Avec ce compte, l'attaquant utilise le canal de maintenance et de mise à jour vers la plateforme de supervision.	Compte prestataire aux droits larges, sans restriction d'horaires ni d'adresses IP, accès permanent plutôt qu'à la demande.	**Connexion du compte du fournisseur hors des plages de maintenance habituelles ou depuis une IP inconnue.**
4. Élévation de privilèges	Il récupère des identifiants d'administration stockés sur la plateforme et obtient des droits sur le cloud et l'hébergeur.	Secrets et mots de passe stockés en clair ou mal protégés, comptes administrateurs partagés, absence de revue des droits (écart n°2 du Job 1).	**Création de nouveaux comptes administrateurs ou utilisation d'un compte admin à une heure inhabituelle** (journaux d'authentification).
5. Propagation et neutralisation des sauvegardes	Il cartographie le réseau, trouve les systèmes critiques et supprime ou chiffre les sauvegardes.	Réseau peu segmenté entre supervision, bases et sauvegardes, sauvegardes accessibles avec les mêmes droits que la production, journalisation insuffisante (écart n°3 du Job 1).	**Volume anormal de lectures/suppressions sur les sauvegardes, ou connexions entre serveurs qui ne communiquent jamais d'habitude.**
6. Déploiement du rançongiciel	Il déclenche le chiffrement des serveurs et bases de la plateforme, et peut envoyer une commande dégradée aux boîtiers IoT.	Absence de détection comportementale sur les serveurs, processus de mise à jour IoT mal maîtrisé (écart n°1 du Job 1), pas de plan de retour arrière.	Activité disque anormale (chiffrement massif de fichiers), arrêt de services de sécurité, **perte soudaine de contact avec une partie de la flotte**.
7. Extorsion	Message de rançon, menace de publication des données exfiltrées, pression sur la direction et les collectivités.	Absence de plan de gestion de crise testé, de procédure de continuité de service en mode dégradé, et d'exercices avec les collectivités.	Constat direct : indisponibilité de la plateforme et message de rançon (détection trop tardive).

Job 7 : Traitement du risque

Mesures de sécurité par scénario

Scénario 1 : rançongiciel via le fournisseur IoT

Réf.	Mesure	Type
M1	Avenant de sécurité avec le fournisseur IoT : MFA obligatoire, notification d'incident sous 24 h, droit d'audit, exigences sur la sécurité des mises à jour.	Contractuelle
M2	Accès prestataire restreint : comptes nominatifs, MFA, accès ouvert à la demande seulement pendant les plages de maintenance, limitation par adresse IP.	Technique
M3	Processus de mise à jour IoT maîtrisé : mises à jour signées, déploiement progressif par lots, tests préalables, retour arrière possible.	Technique / organisationnelle

Scénario 2 : fraude au paiement via les API

Réf.	Mesure	Type
M4	Limitation du nombre de requêtes sur les API, détection des comportements anormaux (créations de comptes en masse, transactions atypiques) et authentification forte sur les paiements.	Technique
M5	Test d'intrusion et revue de sécurité des API, obligatoires avant leur ouverture aux partenaires.	Organisationnelle
M6	Canal d'alerte dédié avec le prestataire de paiement et clause de partage des indicateurs de fraude.	Contractuelle

Scénario 3 : vol de données via l'hébergeur cloud

Réf.	Mesure	Type
M7	Durcissement du cloud : revue des configurations (stockages exposés, interfaces d'administration), MFA sur tous les comptes administrateurs, chiffrement des bases.	Technique
M8	Minimisation des données : durée de conservation limitée pour l'historique de trajets et de géolocalisation, accès aux bases restreint au besoin.	Organisationnelle (RGPD)
M9	Surveillance des volumes de données sortants avec alerte en cas de transfert anormal.	Technique

Chaîne d'attaque détaillée (Job 6)

Réf.	Mesure	Type

M10	Centralisation des journaux et alertes sur les signaux identifiés : connexion hors plage, création de compte administrateur, suppression de sauvegardes, perte de contact avec la flotte.	Technique
M11	Cloisonnement : segmentation réseau, coffre-fort pour les secrets, sauvegardes immuables ou hors ligne avec test de restauration.	Technique
M12	Plan de gestion de crise rançongiciel avec mode dégradé, contacts d'urgence, et exercice annuel avec les collectivités.	Organisationnelle

Priorisation (matrice impact/effort)

Réf.	Impact	Effort	Catégorie
M2	Fort	Faible	**Gain rapide**
M7	Fort	Faible	**Gain rapide**
M6	Moyen	Faible	**Gain rapide**
M1	Fort	Moyen	**Prioritaire**
M4	Fort	Moyen	**Prioritaire**
M5	Fort	Moyen	**Prioritaire**
M11	Fort	Moyen	**Prioritaire**
M12	Fort	Moyen	**Prioritaire**
M3	Fort	Fort	**Projet structurant**
M10	Fort	Fort	**Projet structurant**
M8	Moyen	Moyen	**À planifier**
M9	Moyen	Fort	**À planifier**

Règle de lecture : on lance d'abord les gains rapides, on engage ensuite les mesures prioritaires, puis on planifie les projets structurants plus lourds. Les mesures à impact moyen et effort élevé passent en dernier.

Feuille de route à 3 horizons

Horizon	Mesures	Logique

Immédiat (< 1 mois)	**M2** (accès prestataire restreint), **M7** (MFA admin et revue de la config cloud), **M6** (canal d'alerte paiement), **M12 version minimale** (liste de contacts et procédure d'alerte), sauvegardes hors ligne (début de M11)	Gains rapides qui réduisent tout de suite les risques les plus graves (rançongiciel, fuite).
Court terme (1 à 6 mois)	**M1** (avenant fournisseur IoT), **M4** (protection des API), **M5** (test d'intrusion avant ouverture des API), **M11** (segmentation, coffre à secrets), **M10 première étape** (centralisation des journaux et alertes prioritaires), **M3 première étape** (déploiement par lots), **M8**	Mesures qui demandent de la négociation, du développement ou de la configuration. L'ouverture des API est conditionnée à M4 et M5.
Moyen terme (6 à 12 mois)	**M3 complet** (chaîne de mise à jour signée), **M10 complet** (supervision étendue, éventuellement externalisée), **M9** (surveillance des sorties de données), **exercice de crise M12** avec les collectivités	Projets structurants et vérification de l'efficacité par un exercice.

Job 8 : Approfondissement : scénario supplémentaire et outil EBIOS RM officiel

Le Job 8 a été fait dans un autre document “EBIOS_RM_Job8_extrait”.

Job 9 : Simulation d'incident

Le scénario inventé

> **Six mois après l'analyse.** Le vendredi soir, un groupe de rançongiciel utilise le compte de maintenance du fournisseur des boîtiers IoT, compromis par phishing. Dans la nuit, il crée un compte administrateur, supprime les sauvegardes, puis chiffre les serveurs de la plateforme de supervision. Le samedi à **06h05**, l'astreinte constate que la plateforme et l'application sont hors service et que **1 700 véhicules sur 4 200** (4 agglomérations sur 6) ne répondent plus. Un message de rançon arrive à 06h20 avec un échantillon de données d'usagers, et menace de publier **environ 300 000 comptes**. Dans la matinée, deux usagers signalent que leur trottinette s'est bloquée en roulant, dont une chute avec blessure légère.

Chronologie utile :

Moment	Événement
Vendredi 22h40	Connexion du compte du fournisseur IoT depuis une adresse étrangère, hors plage de maintenance.

Vendredi 23h15	Création d'un compte administrateur inconnu.
Samedi 02h10	Suppression des sauvegardes.
Samedi 05h30	Début du chiffrement des serveurs.
Samedi 06h05	**Détection par l'astreinte (heure qui lance les délais).**
Samedi 06h20	Message de rançon avec échantillon de données.

1. Fiche de qualification de l'incident

Rubrique	Contenu
Premiers signaux	Plateforme et application indisponibles, 40 % de la flotte hors ligne, message de rançon. Avec le recul, des signaux étaient visibles dès vendredi : connexion hors plage du compte fournisseur (22h40), création d'un compte administrateur (23h15), suppression de sauvegardes (02h10).
Nature	Incident de sécurité **malveillant** : rançongiciel avec **exfiltration de données** (double extorsion), accès initial par un **tiers** (fournisseur IoT).
Périmètre	Plateforme de supervision cloud, bases de données et sauvegardes, 1 700 boîtiers IoT dans 4 agglomérations, environ 300 000 comptes usagers (identité, historique de trajets, géolocalisation).
Impact D/I/C	**Disponibilité** : service interrompu, reprise estimée > 72h. **Confidentialité** : atteinte **avérée** (échantillon fourni par les attaquants). **Intégrité** : atteinte suspectée (blocages de trottinettes en roulant, à confirmer).
Gravité	**G4, critique** (échelle du Job 2) : arrêt du service sur plusieurs agglomérations pendant plus de 72h, fuite massive de données de géolocalisation, atteinte physique légère d'un usager avec risque d'aggravation.
Statut	Incident **en cours**, non maîtrisé. Détecté Samedi à 06h05.

2. Notifications (délais calculés depuis 06h05)

Destinataire	Échéance	Statut
ANSSI / CERT-FR, alerte précoce	**Dimanche 06h05** (24 h)	À envoyer samedi en début d'après-midi (projet ci-dessous).
ANSSI / CERT-FR, notification d'incident	**Mardi 06h05** (72 h)	Avec évaluation de gravité et indicateurs de compromission.

ANSSI / CERT-FR, rapport final	**1 mois** après la notification	Analyse des causes et mesures correctives.
CNIL	**Mardi ~06h20** (72 h après la connaissance de la violation)	Violation de données personnelles **avérée** avec échantillon. Notification en plusieurs temps possible.
Usagers	Dès que possible	Risque élevé (géolocalisation), information individuelle nécessaire.
Collectivités partenaires	**Samedi matin**, immédiat	Service public touché, obligations des contrats de DSP.
Assureur cyber	Samedi, selon le contrat	Déclaration rapide pour garder le bénéfice de la couverture.
Fournisseur IoT	**Immédiat**	Pour couper ses accès et obtenir ses journaux.

Pour le TP, je considère MobiCité comme entité soumise à NIS2, comme l'indique mon sujet.

3. Projet de notification d'alerte précoce (24h)

Objet : Alerte précoce, incident de sécurité significatif (art. 23 NIS2)
Date d'envoi : samedi, 13h30 (délai limite : dimanche 06h05).

Entité : MobiCité, opérateur de mobilité partagée, délégataire de service public dans 6 agglomérations françaises. Contact : référent sécurité, [téléphone, e-mail].

Détection : samedi à 06h05, par l'astreinte de la DSI.

Description : compromission de la plateforme de supervision cloud avec chiffrement des serveurs et perte de communication avec environ 1 700 véhicules connectés sur 4 agglomérations.

Suspicion d'acte malveillant : oui. Rançongiciel avec demande de rançon et menace de publication de données. L'accès initial semble passer par le compte de maintenance d'un prestataire, à confirmer.

Impact transfrontalier : aucun connu (activité uniquement en France).

Impact connu à ce stade : service interrompu dans 4 agglomérations, données personnelles d'usagers potentiellement exfiltrées (un échantillon a été fourni par les attaquants), deux signalements de blocage de trottinettes en circulation dont une blessure légère.

Mesures prises : accès du prestataire révoqué, comptes administrateurs suspects désactivés, systèmes touchés isolés, canal de mise à jour des boîtiers coupé, cellule de crise activée à 07h00, collectivités informées à 08h00.

Prochaine étape : notification d'incident complète avant mardi 06h05.

4. Trois actions immédiates de gestion de crise (par priorité)

Priorité	Action	Responsable	Délai	Justification
1. Confinement	Révoquer les accès du fournisseur IoT et les comptes administrateurs inconnus, couper le canal de mise à jour vers les boîtiers, isoler les serveurs touchés, **conserver les journaux et les disques** pour l'enquête.	RSSI + DSI	Dans l'heure	Arrêter la propagation et empêcher de nouvelles commandes vers les véhicules, avant toute autre action.
2. Sécurité des usagers et continuité	Prévenir les équipes terrain pour sécuriser les véhicules concernés, suspendre le service là où la fiabilité des boîtiers n'est pas garantie, informer les usagers par un canal alternatif (site, réseaux sociaux, SMS), prendre en charge les usagers blessés.	Direction exploitation	Dans les 2h	La sécurité physique est la valeur métier la plus critique (G4). La continuité en mode dégradé vient après.
3. Communication et notifications	Activer la cellule de crise, envoyer l'alerte précoce à l'ANSSI, informer collectivités, assureurs, fournisseur IoT, préparer la notification CNIL, fixer **un message unique** pour usagers et presse, sans céder à la pression de la rançon sans décision de la direction.	Direction + communication	Alerte précoce avant 24h, premier message public dans la journée	Les délais réglementaires courent et la confiance des collectivités est en jeu. Un message contradictoire aggraverait l'atteinte à l'image.